

Introduzione

In questo documento verrà presentato il progetto di fine corso per il percorso Academy Cyber + AI. Durante il corso è stata fatta una overview generale sulle AI con un focus in particolare sugli ultimi sviluppi in ambito RAG e Agentic AI, dopo questa parte è stata fatta una overview sulla cybersecurity.

L'obiettivo del progetto è quindi quello di unire i due macroargomenti del corso, andando ad applicare l'agentic AI in ambito cybersecurity, a tale scopo si è quindi scelto di creare un agente AI per aiutare le aziende nella compliance al GDPR.

Abstract

L'agente AI sviluppato in questo progetto è concepito per supportare le aziende nella compliance al GDPR, automatizzando l'analisi e la validazione dei trattamenti di dati personali. In particolare, l'agente è in grado di eseguire un processo di Retrieval-Augmented Generation (RAG) sui testi normativi del GDPR, sulle policy aziendali caricate manualmente e sui provvedimenti e linee guida disponibili sui portali [italiano](#) ed [europeo](#) dedicati alla protezione dei dati.

Grazie a questa metodologia, l'agente può identificare categorie di dati coinvolti, verificare la base giuridica dei trattamenti, valutare il rischio per i diritti e le libertà degli interessati e suggerire misure tecniche e organizzative adeguate. I report generati includono valutazioni complete per la compliance generale e, se necessario, bozza di Valutazioni d'Impatto sulla Protezione dei Dati (DPIA).

Un ulteriore punto di forza dell'agente è la capacità di aggiornarsi automaticamente con l'introduzione di nuovi articoli, linee guida o provvedimenti, garantendo così una conformità continua anche in un contesto normativo in rapido cambiamento. L'approccio combina capacità di comprensione del linguaggio naturale, gestione dinamica delle informazioni e supporto decisionale, con l'obiettivo di ridurre il rischio legale, migliorare la governance dei dati e liberare risorse umane dalle attività ripetitive di analisi normativa.

Contesto

L'entrata in vigore del Regolamento generale sulla protezione dei dati (GDPR) ha introdotto un modello di compliance fondato sul principio di accountability, imponendo a titolari e responsabili del trattamento un approccio proattivo, documentato e basato sul rischio

Il quadro normativo in materia di protezione dei dati è in costante evoluzione, per cui oltre al testo del GDPR assumono importanza anche i provvedimenti e le linee guida delle autorità di controllo.

In questo contesto caratterizzato da crescente complessità regolatoria, aumento delle sanzioni e maggiore consapevolezza degli interessati, l'impiego di strumenti basati su intelligenza artificiale consente di automatizzare l'analisi documentale, migliorare la capacità di aggiornamento normativo e supportare processi decisionali conformi ai principi di protezione dei dati.

Dotarsi di strumenti dinamici e aggiornabili rappresenta quindi un fattore strategico per ridurre il rischio legale e migliorare la governance dei dati.

Idea Progettuale

L'idea centrale è creare un agente software intelligente, in grado di aggiornarsi autonomamente con le nuove norme, che dato in input la descrizione del trattamento (per esempio la creazione di un sistema CRM), sia in grado di classificare categorie dati coinvolti (comuni, particolari giudiziari), identificare la base giuridica applicabile, valutare il livello di rischio per i diritti e le libertà degli interessati, suggerire misure tecniche e organizzative adeguate.

Dopo aver valutato queste cose l'agente potrà quindi generare un report di compliance, report per la valutazione d'impatto sulla protezione dei dati (DPIA).

Inoltre se all'agente saranno fornite anche le policy aziendali riguardo i dati e/o i dati già a disposizione, potrà verificare la base giuridica dei trattamenti già in atto.

Casi d'Uso

Caso d'Uso	Descrizione
Validazione Nuovo Trattamento	L'Agente AI analizza una nuova iniziativa (es. attivazione CRM, piattaforma marketing, sistema HR) e verifica categorie di dati, finalità, base giuridica e rischi prima della messa in esercizio.
Supporto alla DPIA	Identificazione automatica dei trattamenti ad alto rischio e generazione di una bozza strutturata di Valutazione d'Impatto (DPIA), con analisi dei rischi e misure di mitigazione suggerite.
Verifica Base Giuridica	Analisi della coerenza tra finalità dichiarata e base giuridica indicata (consenso, obbligo

Caso d'Uso	Descrizione
	legale, contratto, legittimo interesse), con segnalazione di criticità.
Controllo Minimizzazione e Conservazione	Verifica della proporzionalità dei dati raccolti rispetto alle finalità e analisi dei tempi di conservazione dichiarati.

Osservazioni Preliminari

- L'efficacia dell'agente dipenderà dalla qualità del prompt, più sarà dettagliata la descrizione del trattamento, per esempio descrivendo anche tutti i dati che verranno usati, più sarà dettagliato il report.
- Sarà necessaria la supervisione umana per il controllo delle informazioni reperite online.
- Sarà necessaria la supervisione umana per il controllo della validità dei report generati.

Studio dello Stato dell'Arte

Questa sezione esplorerà le ricerche e i prodotti esistenti che combinano AI e analisi normativa.

- **LLM per l'analisi normativa:** [Esistono già](#) soluzioni che dimostrano la capacità degli LLM per la comprensione e interpretazione di testi normativi complessi e per la conseguente generazione di report.
- **RAG per l'analisi normativa:** Le RAG in generale hanno raggiunto ottime performance, ma per l'applicazione in campo legale è necessario prendere alcuni accorgimenti visto la struttura e il lessico delle norme giuridiche. Per esempio sarà molto importante scegliere il chunk giusto (un articolo = un chunk oppure un comma=un chunk), sarà inoltre cruciale anche la scelta dell'embedding.
- **Piattaforme di compliance al GDPR Basate su AI:** Come dimostrato da [questa soluzione](#) è possibile utilizzare le capacità degli LLM e delle RAG per la generazione di report di compliance al GDPR. Questa applicazione però funziona solo con trattamenti già esistenti e non aiuta nella creazione di nuovi trattamenti, inoltre entrambe le applicazioni precedentemente introdotte sono a pagamento, mentre questo progetto sarà open source.
- **AI Etica e Bias:** Sarà sempre comunque necessario uno human in the loop per la validazione dei report e delle fonti, e che si assuma la responsabilità di quanto fatto.

Tecnologie Esistenti

Verranno analizzate le tecnologie fondamentali che saranno utilizzate o su cui si baserà il progetto:

- **Linguaggi di Programmazione:** Python.
- **Framework ML:** Langchain per la RAG, Ollama per integrare un LLM.
- **Altri framework:** Streamlit per il frontend. BeautifulSoup per il web scraping.

Sviluppo del Progetto

Sia che si vada a considerare un nuovo trattamento o che si consideri uno già esistente il funzionamento dell'agente è lo stesso, quindi per sviluppare il modello conviene considerare un trattamento già esistente per cui sono già stati creati manualmente tutti i report necessari.

In questo modo sarà possibile testare e affinare il modello affinché i report generati siano il più possibile simili a quelli già prodotti.

Una volta perfezionato il modello ci si aspetta che le performance siano analoghe anche andando a considerare nuovi trattamenti.

Per quanto riguarda i dati reperibili dai portali conviene fare uno scraping senza l'agente sui documenti già disponibili fino a una data di poco precedente a quella di sviluppo, testare e affinare sui documenti restanti le capacità di scraping dell'agente e una volta perfezionato farlo partire con la cadenza desiderata.

Implementazione

L'implementazione pratica del prototipo sarà descritta in dettaglio.

- **Ambiente di Sviluppo:** IDE: vscode, hardware:.
- **Codice Sorgente:** [Organizzazione del codice e documentazione](#).
- **Fase di Test Iniziale:** Per ora è stato testato solo il report per la creazione di un nuovo trattamento.

Analisi del Risultato e Test

La validazione dell'Agente AI sarà un pilastro fondamentale della tesi.

Alcune metriche che potrebbero essere considerate:

Coverage ratio: % delle sezioni obbligatorie presenti nel report.

Concordanza con documenti: usare **retrieval + string matching** per contare quante informazioni chiave del vectorstore sono incluse nel report.

Conteggio entità legali/giuridiche: numero di basi giuridiche menzionate, paragoni con quelle previste per il trattamento.

Metrica	Risultato (Atteso)	Risultato (Ottenuto)
Coverage ratio		
Concordanza con documenti		
Conteggio entità legali/giuridiche		

Sviluppi Futuri

Questa sezione delinea le possibili evoluzioni del progetto oltre la tesi.

- Miglioramento continuo performance.
- Integrazione multi-lingua e multi-giurisdizione, considera analogo extra-UE del GDPR.
- Personalizzazione per settori verticali, possibile creare e specializzare un agente per ogni settore(sanità, HR...)

Conclusioni

Il progetto ha dimostrato come un agente AI possa essere applicato in maniera concreta al supporto della compliance al GDPR, combinando capacità di analisi normativa, RAG e LLM per generare report automatizzati e suggerire misure di mitigazione dei rischi.

L’approccio proposto consente non solo di analizzare trattamenti già esistenti, ma anche di valutare nuovi trattamenti in fase di progettazione, aumentando la proattività delle aziende nella gestione della privacy e dei dati personali. L’integrazione di fonti normative aggiornate quotidianamente garantisce un alto livello di affidabilità e tempestività dell’agente, sebbene la supervisione umana resti fondamentale per convalidare le informazioni e mitigare eventuali bias o errori interpretativi.

I test preliminari sul prototipo hanno confermato la fattibilità tecnica del progetto e l’efficacia del modello nel generare report coerenti con quelli già esistenti. Le metriche di copertura e concordanza indicano come l’agente sia in grado di estrarre le

informazioni rilevanti dai documenti normativi e dalle policy aziendali, anche se ulteriori ottimizzazioni sono necessarie per raggiungere livelli di precisione comparabili a quelli di esperti umani.

In prospettiva, il progetto rappresenta una base solida per lo sviluppo di strumenti open source per la compliance al GDPR, con potenziali applicazioni anche in altri ambiti regolatori. L'adozione di un agente AI dinamico e aggiornabile può diventare un fattore strategico per le aziende, riducendo il rischio legale, migliorando la governance dei dati e liberando risorse umane da attività ripetitive di analisi documentale.